

Mr. Fuzail Khan | Certified ISO/IEC 27001:2022 Lead Auditor by Mastermind | [Credentials](#)

PUBLIC - EDUCATIONAL USE ONLY

SIMULATED THIRD-PARTY SUPPLY CHAIN AUDIT REPORT

**ISO/IEC 27001:2022 Information Security
Management System Assessment**

Target Organisation: Sigstore Project (Cosign, Rekor & Fulcio)
A Linux Foundation / OpenSSF Initiative

Report Date	July, 2026
Report Reference	SA-SIGSTORE-2026-001
Lead Auditor	Fuzail Khan, ISO/IEC 27001:2022 Lead Auditor
Training Provider	Mastermind - Simulated Audit (Educational Purposes Only)
Document Version	v1.0 - Final
Audit Standard	ISO/IEC 27001:2022 with Annex A 2022 Controls
Scope Summary	Cosign, Rekor, Fulcio - Engineering Governance, Cryptographic Infrastructure & SDLC
Classification	PUBLIC - Open-Source Simulation / Portfolio Project

⚠ FORMAL DISCLAIMER

This report is a simulated, educational audit conducted entirely via publicly available open-source information. It does not represent a formal ISO/IEC 27001:2022 certification audit, does not constitute legal or regulatory advice, and does not imply any official assessment of, or endorsement by, the Sigstore project, the Linux Foundation, or any accredited certification body. No confidential or proprietary information was accessed or used in the preparation of this report. This document has been produced solely for professional portfolio and educational purposes.

Prepared by: Mr. Fuzail Khan Personal Portfolio Project Document v1.0 - Final

Summary - For Non-Technical Readers

The full technical findings, evidence base, and formal audit conclusions begin on the following page.

What is Sigstore and why does it matter?

Every time you download a software application, install a library, or pull a container image, you are trusting that the software has not been tampered with since the developer created it. Sigstore is a free, publicly available service - used by companies including Google, GitHub, and Red Hat - that allows software developers to cryptographically sign their work. Think of it as a global, tamper-proof notary service for software. When a developer releases code through Sigstore, a permanent, unfalsifiable record is created proving who signed it, when, and from where. This matters because software supply chain attacks - where malicious code is inserted into trusted software packages before they reach end users - are among the fastest-growing categories of cybersecurity threat globally.

What is this audit?

This document is a simulated ISO/IEC 27001:2022 information security audit of the Sigstore project, conducted entirely using publicly available information for educational and professional portfolio purposes. ISO 27001 is the internationally recognised standard for information security management - the same standard that banks, hospitals, and government agencies use to certify that their security practices meet a rigorous, independently verified benchmark. This audit applies that same framework to Sigstore's governance structure, cryptographic infrastructure, and secure development practices.

What did the audit find?

The audit identified no critical security failures. All ten of the most important security controls governing Sigstore's core cryptographic infrastructure - the systems that issue digital certificates, maintain the transparency log, and protect the root of trust - were found to be fully implemented and effective.

Six minor administrative gaps were identified. None of these represent a technical security failure. They represent areas where formal documentation or governance processes have not yet been established to the level required by the standard - for example, the absence of a formal disaster recovery plan with documented recovery time targets, and the absence of a structured internal audit programme. These are common findings even in mature organisations transitioning to ISO 27001 certification.

Nine additional observations were noted as opportunities for improvement. The most technically interesting of these is an unresolved tension between European data protection law (GDPR) and a core architectural design decision: once a user's email address is recorded in Sigstore's transparency log as part of a signing event, it cannot be deleted - because deleting it would break the cryptographic integrity of the log that makes the whole system trustworthy. This is a genuine, publicly acknowledged trade-off with no perfect resolution.

1. Executive Summary

Recommendation	Major NCRs	Minor NCRs	Observations
Certify with Conditions	0	6	9

Zero Major NCRs confirmed - all ten critical cryptographic infrastructure controls verified as fully implemented and effective.

This simulated desk review of the Sigstore project's Information Security Management System identified zero Major non-conformities and confirmed that all ten critical risk-register controls governing the project's core cryptographic trust infrastructure are fully implemented and effective. Six Minor NCRs were raised against administrative and process controls, primarily reflecting the inherent friction of applying traditional ISO 27001 requirements to a distributed, open-source governance model rather than systemic failures of security architecture. Nine Observations were identified representing opportunities to strengthen documentation governance, formalise existing informal practices, and address an unresolved architectural tension between GDPR erasure obligations and the cryptographic immutability of the Rekord transparency log.

Commercial Software Vendors (EU Market Distributors)	Immutable digital signatures and machine-readable attestations to certify product integrity and a secure development lifecycle.	EU Cyber Resilience Act (CRA) - Essential Cybersecurity Requirements for Products with Digital Elements
US Federal Agencies & Government Contractors	Cryptographically signed software artifacts and non-falsifiable provenance documentation to satisfy federal procurement criteria.	US Executive Order 14028 - Improving the Nation's Cybersecurity / NIST SP 800-218 SSDF Compliance
Kubernetes / CNCF Ecosystem Consumers (Kyverno, OPA Gatekeeper)	High availability and low-latency verification from the public-good infrastructure (Rekor, Fulcio) to enforce cluster admission policies without blocking valid deployments.	CNCF Software Supply Chain Best Practices - Cloud Native Operational Resilience
Package Registries & CI/CD Platforms (npm, GitHub Actions)	High throughput and cryptographic integrity of the transparency log to automatically generate and verify build attestations linked to source repositories.	SLSA (Supply-chain Levels for Software Artifacts) - Non-falsifiable Provenance Framework
LF Projects LLC & OpenSSF (Governance & Parent Bodies)	Adherence to transparent governance structures, maintenance of security standards, and protection of trademark and domain assets.	Sigstore Project Charter (Section 5) & OpenSSF Best Practices Badge Criteria

3.3 ISMS Scope Statement (Clause 4.3)

The scope of the Information Security Management System (ISMS) for the Sigstore project, governed by the Technical Steering Committee (TSC), encompasses the engineering governance, secure development lifecycle, and cryptographic infrastructure of its core components (Cosign, Rekor, Fulcio) and their live public-good production instances. The boundary explicitly includes the TUF root-signing infrastructure, as it houses the foundational cryptographic trust anchor essential to ecosystem integrity. Conversely, the Kubernetes Policy Controller and language SDKs are explicitly excluded, as they operate strictly as downstream API consumers rather than authoritative generators of trust material. Physical corporate security is also excluded due to the project's completely distributed, open-source nature. Finally, the ISMS interfaces with, but does not control, critical external dependencies, specifically relying on GitHub for repository hosting and pipeline execution, third-party OpenID Connect (OIDC) providers for user identity authentication, and Google Cloud Platform (GCP) for the hosting and operation of the live public-good production infrastructure.

Scope Boundary Summary

Dimension	Detail
In Scope - Systems	Cosign (codebase & CLI), Rekor (transparency log service), Fulcio (certificate authority), TUF Root-Signing Infrastructure (sigstore/root-signing), Timestamp Authority (TSA), Sigstore Public-Good Production Infrastructure (rekor.sigstore.dev, fulcio.sigstore.dev)
In Scope - Functions	Engineering governance (documented TSC policies and procedural outputs), cryptographic infrastructure design and operations, secure development lifecycle including CI/CD pipeline security, artifact signing workflows, and vulnerability management.

4.1.3 Impact Scale

Level	Rating	Sigstore Ecosystem Impact
Insignificant	1	A brief latency spike in Rekor log ingestion that does not violate published SLOs; a cosmetic bug in Cosign CLI output that does not affect cryptographic verification integrity.
Minor	2	Transient downtime of the public Fulcio instance of less than 15 minutes causing temporary CI/CD pipeline delays for downstream consumers, without data loss or any invalidation of existing trust material.
Moderate	3	A significant outage of rekor.sigstore.dev exceeding one hour, violating published SLOs; or a vulnerability allowing bypass of local Cosign verification under highly specific non-default conditions while leaving the root of trust intact.
Major	4	Compromise of an automated KMS online signing key requiring immediate revocation and emergency rotation; or unauthorised write access to a core repository resulting in a malicious commit that is detected and caught prior to release.
Severe	5	Catastrophic compromise of the TUF root (trusted_root.json) or the offline hardware keys of multiple keyholders; or undetectable tampering, truncation, or silent forking of the immutable Rekor transparency log, permanently undermining the cryptographic trust foundation of the global software supply chain.

4.1.4 Risk Scoring Matrix

L \ I	1 Insignificant	2 Minor	3 Moderate	4 Major	5 Severe
5 Almost Certain	5	10	15	20	25
4 Likely	4	8	12	16	20
3 Possible	3	6	9	12	15
2 Unlikely	2	4	6	8	10
1 Rare	1	2	3	4	5

7.4 Technological Controls (A.8.1 – A.8.34)

The following table documents Stage 2 evidence verification findings for Technological controls, covering all risk-register-linked controls, Not Implemented controls, and Partially Implemented controls identified in the Statement of Applicability.

Control ID	Evidence Examined	Evidence Reference	Verification Finding	Basis for Finding
A.8.24	Root-signing repository structure, architecture documentation	EV-004, EV-007	Conforming	The 3-of-5 threshold configuration is explicitly documented within the sigstore/root-signing repository. Architecture documentation details Rekor's Merkle tree and signed tree head mechanisms, satisfying cryptographic operational control requirements.
A.8.28	CI/CD workflow files across core repositories	EV-006	Conforming	Examination of CI/CD workflow files confirms that golanci-lint and CodeQL are configured as mandatory status checks required to pass prior to merging code, actively enforcing secure coding standards.
A.8.29	OSS-Fuzz integrated projects list, CI/CD configurations	EV-006, EV-015	Conforming	Sigstore is confirmed as integrated into the OSS-Fuzz programme (EV-015), demonstrating continuous automated fuzz testing of core components including Fulcio's OIDC token validation logic.
A.8.15	Infrastructure documentation, Terraform configurations	EV-006, EV-008	Conforming	Infrastructure documentation and Terraform configurations explicitly reference GCP Cloud Logging for secure aggregation and retention of operational logs.
A.8.16	Architecture and infrastructure documentation	EV-007	Conforming	Architecture documentation confirms the integration and active use of Prometheus and Grafana for continuous system health monitoring and API anomaly detection.
A.8.8	Core repository CI/CD configurations	EV-006	Conforming	The .github/dependabot.yml configuration files are verified as present across the Cosign, Rekor, and Fulcio repositories, confirming automated dependency management and vulnerability detection are actively implemented.
A.8.9	CI/CD workflow configurations	EV-006	Conforming	CI/CD workflow configurations demonstrate the deliberate absence of pull_request_target triggers in Cosign. Workflow permission scopes are explicitly set to minimum required access, enforcing strict configuration management controls.
A.8.32	Repository settings documentation, CONTRIBUTING.md	EV-006, EV-011	Conforming	Branch protection rules are confirmed as enforced, mandating peer reviews and passing status checks while explicitly preventing direct commits to the main branch across core

OFI CARD 9:

Field	Detail
OFI Reference	OFI-009
Classification	Observation / OFI
ISO 27001:2022 Clause	9.3 - Management review
Annex A Control	-
Finding	No evidence exists of a formal scheduled ISMS management review cycle that explicitly processes the mandatory Clause 9.3 inputs including status of previous actions, changes in external and internal issues, security performance results, nonconformity status, and resource adequacy assessment. Informal TSC governance meetings do not satisfy this requirement.
Evidence of Observation	EV-001, EV-003 - review of TSC governance documentation and meeting records confirmed informal discussions do not satisfy the mandatory Clause 9.3 input requirements.
Recommended Action	Establish a formal annual ISMS management review cycle that explicitly addresses all mandatory Clause 9.3 inputs and documents the resulting security posture decisions and resource commitments.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

8.3 CAPA Plan

The following Corrective Action and Preventive Action plan documents the root cause, assigned remediation owner, target date, and verification method for each of the six Minor NCRs identified during this audit. Corrective action closure will be confirmed upon submission of objective evidence to the audit team within the stipulated 90-day period.

NCR Ref	Root Cause	Corrective Action	Responsible Party	Target Date	Verification Method
NCR-001	No formal escalation pathway to external authorities was established when the security governance model was designed, as the open-source community model assumed informal reliance on Linux Foundation legal counsel.	Document a formal authority contact procedure specifying trigger conditions, responsible contact roles, and Linux Foundation legal escalation pathway.	TSC	Report Date + 90 days	Procedure document published in community repository and referenced in SECURITY.md